

NorthBridge Technology Solutions Inc.
Information Security Management System

Information Security Risk Assessment
Methodology

DOCUMENT CONTROL	
Document Title	Information Security Risk Assessment Methodology
Document ID	NB-ISMS-003
Version	1.0
Date	05/15/2026
Author	Ashkon Irani
Reviewed By	IT Director
Approved By	Chief Executive Officer
Classification	Confidential

1. Purpose

The purpose of this document is to define the methodology used by NorthBridge Technology Solutions Inc. to identify, analyze, evaluate, and treat information security risks within the scope of its Information Security Management System (ISMS). This methodology establishes a consistent, repeatable, and auditable approach to risk assessment in accordance with ISO/IEC 27001:2022 Clause 6.1.2 and the organization's overall commitment to protecting the confidentiality, integrity, and availability of its information assets.

This document governs all formal risk assessment activities conducted within NorthBridge and serves as the authoritative reference for scoring criteria, risk acceptance thresholds, and treatment options used in the NorthBridge Risk Register (NB-ISMS-004).

2. Scope

This methodology applies to all information security risk assessments conducted within the scope of NorthBridge's ISMS, as defined in the ISMS Scope and Context Statement (NB-ISMS-001). It applies to all information assets identified in the NorthBridge Asset Inventory (NB-ISMS-002), and to all personnel responsible for conducting, reviewing, or approving risk assessments, including the IT Director, the Information Security team, and departmental asset owners.

This methodology applies to scheduled annual risk assessments, ad-hoc assessments triggered by organizational changes or incidents, and targeted assessments conducted following the introduction of new systems, services, or regulatory requirements.

3. Risk Assessment Overview

NorthBridge's risk assessment process follows a four-stage lifecycle aligned with ISO/IEC 27001:2022 Clause 6.1.2 and guidance from NIST Special Publication 800-30 Revision 1. The four stages are applied to all in-scope information assets on an annual basis, and on an ad-hoc basis following significant organizational changes, security incidents, or the introduction of new systems or services.

Stage	Name	Description
1	Risk Identification	Identify threats to information assets and the vulnerabilities those threats could exploit. All asset types in the NorthBridge Asset Inventory must be considered.
2	Risk Analysis	Assess the likelihood of each risk materializing and the impact if it does, producing a numerical risk score using the 5x5 scoring matrix defined in Section 6.
3	Risk Evaluation	Compare each risk score against NorthBridge's defined risk acceptance criteria (Section 8) to determine whether treatment is required.
4	Risk Treatment	Select and implement an appropriate treatment option: Mitigate, Transfer, Accept, or Avoid, for all risks that exceed the acceptance threshold.

Risk assessments are documented in the NorthBridge Risk Register (NB-ISMS-004) and reviewed by the IT Director on a quarterly basis. The full risk assessment cycle is completed annually, and results are presented to executive leadership as part of the ISMS management review process.

4. Key Definitions

The following definitions apply throughout this methodology and the NorthBridge Risk Register. All risk assessment activities conducted within the ISMS scope use these terms consistently to ensure clarity and comparability of results.

Term	Definition
Threat	Any circumstance or event with the potential to adversely impact organizational assets through unauthorized access, destruction, disclosure, modification, or denial of service.

Vulnerability	A weakness in an information asset, system, process, or control that could be exploited by a threat to cause harm to the organization.
Risk	The potential for loss or harm resulting from a threat exploiting a vulnerability. Risk is expressed as a combination of the likelihood of a threat event occurring and the impact it would have on the organization if it did.
Likelihood	The probability that a specific threat will successfully exploit a specific vulnerability within a defined timeframe, typically one calendar year.
Impact	The magnitude of harm that would result if a threat successfully exploited a vulnerability, measured across operational, financial, legal/regulatory, and reputational dimensions.
Inherent Risk	The level of risk that exists before any controls or mitigating actions have been applied. Inherent risk represents the baseline threat to an asset with no security controls in place.
Residual Risk	The level of risk that remains after existing controls and mitigating actions have been applied and accounted for. Residual risk is compared against acceptance criteria to determine whether further treatment is required.
Control	A measure that modifies or reduces risk. Controls may be preventive (stopping a risk from occurring), detective (identifying when a risk has occurred), or corrective (limiting damage after a risk has occurred).
Risk Owner	The individual is accountable for ensuring that a specific risk is appropriately assessed, treated, and monitored. Risk owners are typically the owners of the assets affected by the risk.
Risk Appetite	The amount and type of risk that NorthBridge is willing to accept in pursuit of its strategic objectives. Risk appetite is set by executive leadership and defines the boundary between acceptable and unacceptable risk.

5. Threat and Vulnerability Categories

To ensure consistency and completeness in risk identification, NorthBridge categorizes threats and vulnerabilities according to the following taxonomy. Risk assessors must consider each threat category when reviewing each asset in the Asset Inventory, ensuring no category of threat is overlooked during the identification stage.

Threat Category	Examples Relevant to NorthBridge
Malicious External Actor	Ransomware attacks, phishing campaigns targeting staff, DDoS attacks on cloud infrastructure, supply chain attacks, and nation-state targeting of government contractors.
Malicious Insider	Disgruntled employee exfiltrating Protected B data, contractor misusing privileged access credentials, deliberate sabotage of systems or source code repositories.
Accidental Insider	Employee misconfiguring an Azure environment, accidental deletion of client data, sending sensitive information to an incorrect recipient, and unintentional policy violations.
Physical and Environmental	Fire or flood at the Ottawa HQ, power failure affecting the server room, theft of an employee laptop, unauthorized physical access to restricted areas.

Technical Failure	Hardware failure of on-premises network equipment, software bugs in deployed applications, Microsoft Azure regional outage, backup system failure.
Third-Party and Supply Chain	Vendor security breach affecting data shared with NorthBridge, vulnerability introduced via third-party software library, outsourced service provider failure.
Regulatory and Legal	New Government of Canada security directive requiring control changes, audit finding requiring remediation, contractual non-compliance with a client security clause.
Social Engineering	Impersonation of IT staff in phone calls, business email compromise targeting finance team, vishing (voice phishing) targeting executives or IT administrators.

Vulnerability categories used in conjunction with threat identification include configuration weaknesses, missing or inadequate controls, process gaps, human factors, physical security gaps, and third-party weaknesses. For each identified threat-asset combination, assessors must document the specific vulnerability the threat would exploit before assigning likelihood and impact scores.

6. Risk Scoring Methodology

NorthBridge uses a quantitative likelihood-impact scoring methodology to assess information security risks. Each risk is scored on two independent dimensions — likelihood and impact — using a five-point scale. The combined score determines the overall risk level and the required treatment response. This approach is consistent with guidance provided in NIST Special Publication 800-30 Revision 1 and produces results that are consistent, comparable, and auditable across all risk assessment cycles.

Risk Score Formula:

$$\text{Risk Score} = \text{Likelihood Score} \times \text{Impact Score}$$

The result is a value between 1 and 25. Higher scores indicate greater risk. Scores are mapped to risk levels (Low, Medium, High, Critical) as defined in Section 7.

6.1 Likelihood Scale

Likelihood reflects the probability that a specific threat will successfully exploit a specific vulnerability during a 12-month period, considering controls already in place. Assessors must consider the current threat environment, any available historical incident data, and the effectiveness of existing controls when assigning a score.

Score	Rating	Definition
1	Rare	The threat-vulnerability combination is highly unlikely to materialize in a 12-month period. No known historical precedent within the organization or industry. Strong controls significantly reduce probability.

2	Unlikely	The threat could occur but is not expected under normal circumstances. Limited historical precedent in the industry. Controls in place provide meaningful reduction in probability.
3	Possible	The threat may occur at some point during the 12-month period. Some historical precedents in the industry exists. Controls partially reduce probability but gaps remain.
4	Likely	The threat will probably occur within the 12-month period if not actively managed. Clear historical precedent in the sector. Current controls are insufficient or only partially effective.
5	Almost Certain	The threat is expected to occur within the 12-month period. Frequent historical precedent. Few or no effective controls are currently in place.

6.2 Impact Scale

Impact reflects the magnitude of harm to NorthBridge if a risk event occurs. Impact is assessed across four dimensions simultaneously: operational impact (effect on business continuity and service delivery), financial impact (direct costs, fines, and revenue loss), legal and regulatory impact (contractual breaches, regulatory penalties, litigation), and reputational impact (damage to client relationships and public trust). The highest score across any single dimension determines the overall impact rating assigned to the risk.

Score	Rating	Definition
1	Negligible	Minimal disruption to operations. No financial loss or de minimis cost (under \$5,000 CAD). No regulatory implications. No reputational impact. Fully recoverable within hours with no client impact.
2	Minor	Limited disruption affecting a single team or non-critical system. Financial costs under \$10,000 CAD. No regulatory breach but a minor internal policy violation. Minimal reputational impact is contained internally.
3	Moderate	Noticeable disruption affects multiple teams or client-facing services. Financial impact between \$10,000 and \$100,000 CAD. Regulatory notification may be required. Some reputational damage to clients or partners is possible.
4	Significant	Serious disruption to core operations or client services, including GoC contract obligations. Financial impact between \$100,000 and \$1,000,000 CAD. Regulatory breach likely with formal investigation possible. Significant reputational damage affecting client retention.
5	Catastrophic	Complete or near-complete operational failure. Financial impact exceeding \$1,000,000 CAD or existential threat to the business. Serious regulatory penalties, litigation, or criminal investigation. Severe and lasting reputational damage. Loss of Government of Canada contracts.

6.3 Risk Scoring Matrix

The risk score is calculated by multiplying the likelihood score by the impact score. The resulting value between 1 and 25 is mapped to a risk level as defined in Section 7. The matrix below provides a visual reference for all possible score combinations, colour-coded by risk level.

Likelihood \ Impact	Impact 1 Negligible	Impact 2 Minor	Impact 3 Moderate	Impact 4 Significant	Impact 5 Catastrophic
5 — Almost Certain	5	10	15	20	25
4 — Likely	4	8	12	16	20
3 — Possible	3	6	9	12	15
2 — Unlikely	2	4	6	8	10
1 — Rare	1	2	3	4	5

Low (1–6)	Medium (7–12)	High (13–19)	Critical (20–25)
-----------	---------------	--------------	------------------

Risk scores should be interpreted as relative measures rather than absolute values. Two risks with identical scores may require different treatment urgency depending on the speed at which the risk could materialize, the strategic importance of the affected asset, and the availability of treatment options. Assessors must apply professional judgment alongside numerical scoring.

7. Risk Levels and Colour Classification

Risk scores are mapped to four risk levels. Each level carries an associated colour classification used consistently throughout all ISMS documentation, management reporting, and executive dashboards. Risk levels determine the urgency and nature of the required treatment response as defined in Section 8.

Risk Level	Score Range	Colour	Meaning
Critical	20–25	Red	Unacceptable risk requiring immediate escalation to executive leadership and urgent treatment. Activity involving this risk may need to be suspended for pending treatment approval.
High	13–19	Orange	Significant risk requiring a formal treatment plan with a defined owner and target completion date. Escalation to the IT Director is required within five business days.
Medium	7–12	Yellow	Moderate risk requiring a treatment plan within a defined timeframe. Monitored by the IT security team with a quarterly review. May be formally accepted with IT Director approval.
Low	1–6	Green	Acceptable risk within NorthBridge's risk appetite. Documented in the Risk Register and reviewed annually. No immediate treatment is required unless circumstances change.

8. Risk Acceptance Criteria

NorthBridge's risk acceptance criteria have been defined by executive leadership and reflect the organization's risk appetite given its obligations to Government of Canada clients, its regulatory

environment, and its commercial objectives. These criteria apply to residual risk scores; the risk levels remaining after existing controls have been fully accounted for. Inherent risk scores are recorded for reference and trend analysis purposes but do not drive treatment decisions.

Risk Level	Score Range	Acceptance Decision	Required Action
Critical	20–25	Never Acceptable	Immediate escalation to the CEO and IT Director within 24 hours. Formal treatment plan approved within 5 business days. Progress reviewed weekly until residual risk falls below 20.
High	13–19	Not Acceptable	Formal treatment plans are required within 30 days. Risk owner and treatment actions documented in Risk Register. Monthly progress review by the IT Director.
Medium	7–12	Conditionally Acceptable	Treatment plan required within 90 days unless formally accepted by the IT Director with documented justification. Reviewed quarterly.
Low	1–6	Acceptable	Within NorthBridge's risk appetite. Document in Risk Register and review annually. No treatment plan is required unless the risk score increases.

Formal risk acceptance of the decision to accept a risk without treatment requires written approval from the IT Director for Medium risks and from the CEO for High risks. Critical risks may never be formally accepted; they must be actively treated until residual risk falls below the Critical threshold. All risk acceptance decisions are documented in the Risk Register with the approver name, justification, and review date, and are reviewed during the annual ISMS management review.

9. Risk Treatment Options

For all risks identified as requiring treatment, risk owners must select one of the four treatment options defined in this section, consistent with ISO/IEC 27001:2022 Clause 6.1.3. The selected option, along with the specific treatment action, responsible party, and target completion date, must be documented in the NorthBridge Risk Register (NB-ISMS-004).

9.1 Mitigate

Risk mitigation involves implementing controls or actions that reduce the likelihood of a risk occurring, reduce the impact if it does occur, or both. Mitigation is the most common treatment option and should be selected whenever a proportionate control exists that can meaningfully reduce the risk score.

Examples in the NorthBridge context:

- Implementing multi-factor authentication across all Microsoft 365 accounts to reduce the likelihood of credential compromise (RSK-005).
- Enforcing full-disk encryption on all employee laptops to reduce the impact of device loss or theft (RSK-004).
- Deploying endpoint detection and response (EDR) software to reduce the likelihood of undetected malware execution (RSK-001).

- Implementing branch protection rules and mandatory code review in Azure DevOps to reduce the risk of malicious code introduction (RSK-006).

When selecting Mitigate, risk owners must specify the exact control to be implemented, the expected reduction in likelihood and/or impact, the responsible party for implementation, and the target completion date. Mitigation reduces risk; it does not eliminate it. A residual risk score must be recorded after mitigating controls are applied.

9.2 Transfer

Risk transfer involves shifting the financial or operational consequences of a risk to a third party. This treatment option does not eliminate the risk or reduce its likelihood; it changes who bears the financial consequences if the risk materializes.

The most common form of risk transfer in NorthBridge's context is cyber liability insurance, which transfers financial consequences of a breach to an insurer. Contractual indemnification clauses that assign liability to vendors for security failures in their systems represent another form of transfer.

Important limitation: risk transfer does not transfer accountability. If a vendor breach exposes Government of Canada client data held by NorthBridge, contractual liability clauses may shift financial consequences to the vendor, but NorthBridge remains accountable to its government clients and regulators for the breach. Transfer is therefore rarely sufficient as a standalone treatment for High or Critical risks and must be combined with mitigation where possible.

9.3 Accept

Risk acceptance is the formal decision to acknowledge a risk and take no treatment action, either because the cost of treatment outweighs the benefit, because the residual risk already falls within NorthBridge's risk appetite, or because no proportionate treatment option currently exists.

Risk acceptance is not the same as ignoring a risk. Accepted risks must be formally documented in the Risk Register with a written justification, approved by the appropriate authority as defined in Section 8, and reviewed at least annually to confirm that the acceptance decision remains appropriate given any changes in the threat environment or organizational context.

Acceptance is available only for Low risks and, with the IT Director for written approval, for Medium risks. High and Critical risks may not be formally accepted and must be actively treated.

9.4 Avoid

Risk avoidance is the decision to cease or not undertake the activity that creates the risk. By eliminating the activity, the associated risk is also eliminated. This is the most complete form of risk treatment but also the most disruptive, as it always involves a business trade-off.

Risk avoidance is appropriate when a risk cannot be reduced to an acceptable level through mitigation or transfer, and when the business benefit of the underlying activity does not justify the risk, it creates.

Examples in the NorthBridge context:

- Deciding not to permit client Protected B data to be stored on employee personal devices, even with MDM controls; the residual risk remains too high.
- Choosing not to engage a specific third-party vendor whose security posture cannot be adequately verified through the vendor assessment process.
- Discontinuing a legacy application that cannot be patched and introduces an unacceptable vulnerability into the environment.

Avoidance decisions require business leadership involvement, as they eliminate both the risk and the value the underlying activity was generating. This is not a purely technical decision.

10. Roles and Responsibilities

The following roles and responsibilities apply to all risk assessment activities conducted under this methodology. Accountability for each stage of the risk assessment lifecycle is assigned to a specific named role to ensure clarity of ownership and prevent gaps in the process.

Role	Responsibilities	Authority Level
Chief Executive Officer	Approves risk acceptance criteria and organizational risk appetite. Reviews risk summary for annual ISMS management review. Provides written approval for formal acceptance of High risks.	Ultimate accountability for organizational risk posture.
IT Director	Oversees the risk assessment process end-to-end. Reviews and approves the completed Risk Register. Escalates Critical risks to CEO within 24 hours. Approves formal acceptance of Medium risks. Monitors quarterly risk reviews.	Operational authority for information security risk management.
Information Security Analyst	Conducts risk identification and analysis of workshops. Maintains and updates on the Risk Register. Prepares risk summary reports for IT Director review. Coordinates risk assessment activities across departments.	Operational execution of all risk assessment activities.
Asset Owners	Provide subject matter expertise on threats and vulnerabilities affecting their assigned assets. Review and validate risk scores for assets under their ownership. Implement assigned treatment actions and report progress.	Accountable for risks associated with owned assets.
Department Managers	Ensure their teams cooperate with risk assessment activities and timelines. Communicate operational changes that may introduce new risks. Support implementation of treatment actions within their departments.	Accountable for risk awareness and cooperation within their teams.
Legal and Compliance	Advise regulatory and contractual risk implications. Review Risk Register entries with legal or compliance dimensions. Notify IT Director of new regulatory requirements affecting the risk of landscape.	Advisory authority on all legal and regulatory risk matters.

11. Risk Assessment Schedule

NorthBridge conducts risk assessments according to the schedule defined below. ISO/IEC 27001:2022 requires that risk assessments be performed at planned intervals and whenever

significant changes occur, that could affect the organization's risk posture. All assessment activities are documented in the Risk Register with completion dates and reviewer confirmation.

Trigger	Assessment Type	Responsible Party
Annual cycle, every 12 months	Full risk assessment covering all assets within the ISMS scope. Complete review and update of the Risk Register.	Information Security Analyst, reviewed and approved by the IT Director.
Significant organizational change (new system, major process change, significant headcount change, new client engagement)	Targeted assessment of assets and processes directly affected by the change.	Information Security Analyst and relevant Asset Owner.
Security incident rated P1 or P2 under the Incident Response Policy (NB-ISMS-POL-004)	Post-incident risk review to assess whether new risks have emerged, or existing risk scores require updating.	IT Director and Information Security Analyst.
New regulatory requirement or significant change to the external threat landscape	Review of relevant Risk Register entries and associated controls to assess continued adequacy.	IT Director in consultation with Legal and Compliance.

In addition to scheduled assessments, any asset owner who identifies a new threat, vulnerability, or significant change to an existing risk is responsible for notifying the Information Security Analyst promptly so the Risk Register can be updated on an ad-hoc basis between formal review cycles.

12. Document Review and Approval

This methodology shall be reviewed annually by the IT Director and approved by the Chief Executive Officer. Reviews shall also be triggered by significant changes to the organization's risk environment, regulatory landscape, or ISMS scope. Any changes to risk acceptance criteria — including adjustments to score thresholds or approval authorities — require CEO approval prior to implementation and must be version-controlled in accordance with NorthBridge document management standards.

Role	Name	Signature	Date
Author	Ashkon Irani	[Signed]	05/15/2026
Reviewer	IT Director	[Signed]	05/15/2026
Approver	Chief Executive Officer	[Signed]	05/15/2026

— End of Document —

NB-ISMS-003 v1.0 | NorthBridge Technology Solutions Inc. | CONFIDENTIAL